Lab 13B

API Governance

WSO2 API Manager 4.7.0 · Practical exercise

Before You Begin

URLs in this guide use placeholders. Replace them with the values of the API Manager you are using:

- **`<APIM_HOST>`** – host name or IP address of the API Manager server (localhost when API Manager runs on your own laptop).
- **`<HTTPS_PORT>`** – API Manager HTTPS port: 9443 plus any port offset (Publisher, Developer Portal, Admin Portal, Management Console, token endpoint).
- **`<GW_HTTPS_PORT>` / `<GW_HTTP_PORT>`** – API Gateway ports: 8243 (HTTPS) and 8280 (HTTP) plus any port offset.
- **`<APIM_HOME>`** – the folder where API Manager is extracted.

The servers use a self-signed certificate by default, so the browser shows a security warning the first time: choose Advanced and continue.

Training Objective

Learn how to use API governance in WSO2 API Manager 4.7.0 to make APIs follow organisation rules. You write a ruleset, attach it to APIs through a label and a governance policy, see a non-compliant API being blocked at deployment, fix it, and check compliance in the Publisher and the Admin Portal.

Business Scenario

I&M's API team wants every finance API to follow two rules before it reaches the gateway: it must never be offered with the Unlimited business plan, and it must have a technical owner. A finance API that offers Unlimited must not be deployed or published. A missing technical owner is only a warning.

High-Level Steps

- Explore the default rulesets and governance policy
- Create a ruleset with the two finance rules
- Create a label and a governance policy that blocks errors
- Create a finance API and see the deployment blocked
- Fix the API, deploy and publish it
- Check compliance in the Publisher and the Admin Portal

CC BY 4.0

How It Works

Concept	What it is	In this lab
Ruleset	A list of rules (YAML) with a severity: error, warn or info. A ruleset checks the API definition, the API metadata (api.yaml) or the documentation.	`I&M Finance Guidelines`
Label	A tag on an API. Policies attached to a label apply to every API with that label.	`finance`
Governance policy	Groups rulesets, says which APIs they apply to (all APIs or a label), when they run (create, update, deploy, publish) and what to do (Block or Notify).	`Finance API Policy`
Compliance	The result of the checks, shown per API in the Publisher and for all APIs in the Admin Portal.	Compliance pages

Block stops the action at once (synchronous check). It is only possible for API Deploy and API Publish. Notify lets the action go ahead and records the result; the background check runs about every 2 minutes after a change.

In this lab, use the admin user for every portal. In a real team, admins manage rulesets and policies, and API creators and publishers see the results.

Part 1 – Explore the Default Governance Setup

1. Log in to the Admin Portal as admin:

```
https://<APIM_HOST>:<HTTPS_PORT>/admin
```

Example:

```
https://localhost:9443/admin
```

2. In the left menu, open **Governance** → **Ruleset Catalog**. API Manager 4.7.0 comes with these rulesets:

Ruleset	Checks	Applies to
WSO2 API Management Guidelines	API metadata: name, context, version, tags, business owner, HTTPS only...	REST APIs
WSO2 REST API Design Guidelines	API definition (OpenAPI): descriptions, operation IDs, tags, plural resource names...	REST APIs
OWASP Top 10	API definition: security best practices against the OWASP API Top 10	REST APIs
WSO2 MCP Server Management Guidelines	MCP server metadata	MCP servers

CC BY 4.0

3. Click **WSO2 API Management Guidelines** and look at the ruleset content. Each rule has a `severity`, a `given` path (what to check, for example `$.data.name` for the API name) and a `function` (how to check it, for example `truthy` = must be set, or `pattern`).

4. Open **Governance** → **Policies**. The default policy **WSO2 API Management Best Practices** applies to all APIs, runs on API create and update, and only notifies (it never blocks).

Part 2 – Create a Ruleset

5. In **Governance** → **Ruleset Catalog**, click **Create Ruleset** and enter:

Field	Value
Name	`I&M Finance Guidelines`
Description	Rules for finance APIs
Artifact Type	REST API
Ruleset Type	Metadata

6. In **Ruleset Content**, click **Upload File** and select `finance-ruleset.yaml` from the Day 2 **03 Lab Files** folder. Check that the editor shows 18 lines, starting with `rules:` at the far left on line 1, then click **Create**. The file contains:

```
rules:
  finance-no-unlimited-plan:
    description: "Finance APIs must not offer the Unlimited business plan."
    message: "Unlimited plan is not allowed. Use a limited plan such as Gold."
    severity: error
    given: "$.data.policies[*]"
    then:
      function: pattern
      functionOptions:
        notMatch: "^Unlimited$"
  finance-technical-owner:
    description: "Finance APIs must have a technical owner."
    message: "Technical owner is missing. Set it in Business Info."
    severity: warn
    given: "$.data"
    then:
      field: "businessInformation.technicalOwner"
      function: truthy
```

How to read it: `$.data.policies[*]` is each business plan of the API; the rule fails (error) when one of them is exactly Unlimited. The second rule fails (warning) when the technical owner field is empty.

Do not copy the rules from this PDF: copying from a PDF removes the indentation, and the Admin Portal then shows **Ruleset content is invalid**. If you type or paste the rules instead of uploading the file, first clear the editor (click inside it, press `Ctrl+A` / `Cmd+A`, then `Delete`), because pasting into text that is already there adds a second copy, which is also invalid. YAML uses spaces, never tabs.

CC BY 4.0

Part 3 – Create a Label and a Governance Policy

7. In the left menu, open **Labels**, click **Add Label**, enter the name `finance` and the description `Finance APIs`, and click **Save**.

8. Open **Governance** → **Policies** and click **Create Policy**. Under **General Details**, enter the name **Finance API Policy** and a description.

9. Under **Attachment**, choose **APIs with specific labels** and select `finance`.

10. Under **Enforcement**, click **Add Enforcement Criteria**. Set **Governed State** to **API Deploy**, set the actions as below and click **Save**. Then add a second criteria for **API Publish** with the same actions.

Severity	Action
Error	`Block`
Warn	Notify
Info	Notify

11. Under **Rulesets**, add **I&M Finance Guidelines** and click **Create**.

    Block is not offered for API Create and API Update: those states can only notify.

Part 4 – Create a Finance API and See It Blocked

12. Open the Publisher:

```
https://<APIM_HOST>:<HTTPS_PORT>/publisher
```

Example:

```
https://localhost:9443/publisher
```

13. Click **Create API** → **Start From Scratch** (REST API), enter the values below and click **Create**.

Field	Value
Name	`FinanceAccounts`
Context	`/finance-accounts`
Version	`1.0.0`
Endpoint	`https://<APIM_HOST>:<HTTPS_PORT>/am/sample/pizzashack/v1/api/`

CC BY 4.0

14. Go to **Portal Configurations** → **Subscriptions**, select **Unlimited** as the only business plan and click **Save**. (This is the mistake that the policy must catch.)

15. Go to **Portal Configurations** → **Basic Info**. Under **Labels**, attach the `finance` label and click **Save**. The Finance API Policy now applies to this API.

16. Go to **Deploy** → **Deployments**, select the **Default** gateway and click **Deploy**.

    The deployment is blocked. The Publisher shows the rule violations: the error blocks the action, and the warning is listed but does not block on its own.

Rule	Severity	Path	Result
`finance-no-unlimited-plan`	Error	`[data][policies][0]`	Blocks
`finance-technical-owner`	Warn	`[data][businessInformation][technicalOwner]`	Listed only

    Behind the scenes the Publisher gets error code `903300`, "Request does not adhere to governance standards", with lists of blocking and non-blocking violations. Creating a revision is checked in the same way, because it is part of deploying.

Part 5 – Fix the API, Deploy and Publish

17. Go to **Portal Configurations** → **Subscriptions**, clear **Unlimited**, select **Gold** and click **Save**.

18. Deploy again (**Deploy** → **Deployments** → **Deploy**). This time the deployment succeeds: only the warning is left, and warnings only notify.

19. Go to **Portal Configurations** → **Business Info**, set **Technical Owner** to `Finance API Team` and click **Save**.

20. Go to **Publish** → **Lifecycle** and click **Publish**. Publishing is also governed by the policy, and it succeeds because no error is left.

21. Control check: deploy a new revision of an API without the finance label, for example PizzaShack. It deploys normally even if it offers Unlimited, because the Finance API Policy only applies to APIs with the finance label.

Part 6 – Check Compliance

22. In the Publisher, open **FinanceAccounts** and click **Compliance** in the left menu. You see the **Policy Adherence**, **Ruleset Adherence** and **Rule Adherence** sections. Both finance rules are listed under **Passed**.

    If you see "Compliance Check in Progress" or "N/A - Waiting for policy evaluation", wait about 2 minutes and refresh: the background check runs after each change.

    The default policy (WSO2 API Management Best Practices) also shows results for this API, for example warnings that operations should have a description, the API should have tags, or the OpenAPI definition should have contact and license information. These only notify.

CC BY 4.0

23. In the Admin Portal, open **Governance → Compliance**. The **Compliance Dashboard** shows the compliance of all APIs and the adherence of each policy. Click **FinanceAccounts** to see the same details as in the Publisher.

Expected Outcome

The ruleset I&M Finance Guidelines and the Finance API Policy are in place. Any API with the finance label that offers the Unlimited business plan cannot be deployed or published (error 903300 with the rule violations), while a missing technical owner is only reported as a warning. APIs without the label are not affected.

After the fix, FinanceAccounts is deployed and published, and its compliance is visible in the Publisher (Compliance) and in the Admin Portal (Governance → Compliance).

CC BY 4.0